



Smoke Test Repo & Risultati Attesi

Riferimento per verificare una run dell'agente sulla repo di test. Cosa contiene, dove, cosa l'agente DOVREBBE trovare, e dove guardare gli output.

Dove si trova la repo di test

```
C:\Users\ladyc\Documents\TRAINEESHIP\CodeQL_Security_Agent\_smoketest_repo\
```

È una repo "trappola" minima: contiene esattamente i due casi che la suite CodeQL standard tende a mancare (wrapper DB custom + hash debole), per verificare i template name-based end-to-end.

Cosa contiene

app.py — SQL Injection (CWE-89)

App Flask con SQLi che passa per un **wrapper DB custom** (`queryDB`), non modellato dalle query standard.

Riga	Codice	Ruolo
16	<code>uid = request.args.get("id")</code>	Source remoto (input utente)
17	<code>sql = "SELECT * FROM users WHERE id = " + uid</code>	Concatenazione non sanitizzata
18	<code>db.queryDB(sql)</code>	Sink SQL con nome custom

crypto_util.py — Weak Hash (CWE-328)

Due usi di hash crittograficamente deboli.

Riga	Codice	Ruolo
5	<code>hashlib.md5(data).hexdigest()</code>	Hash debole per nome diretto
9	<code>hashlib.new("sha1")</code>	Algoritmo debole via argomento-costante

Risultati attesi (checklist post-run)

#	Vulnerabilità	CWE	File : riga	Come dovrebbe trovarla
1	SQL Injection	CWE-89	<code>app.py:18</code>	<code>check_sql_injection</code> oppure <code>run_taint_query</code> con <code>queryDB</code> tra i sink
2	Weak hash (md5)	CWE-328	<code>crypto_util.py:5</code>	<code>check_weak_hash</code> oppure <code>run_api_misuse_query</code>
3	Weak algo (sha1)	CWE-328	<code>crypto_util.py:9</code>	<code>check_weak_hash</code> (match su costante "sha1")

Run riuscita = il report contiene CWE-89 (`app.py`) e CWE-328 (`crypto_util.py`, 2 occorrenze). Se manca il CWE-328, il modello non ha eseguito i check crypto.

Dove vedere gli output dopo la run

Cosa	Percorso	
Report finale (Markdown)	il file passato a <code>--report</code> (es. <code>report_abliterated.md</code>) nella cartella del progetto	
Database CodeQL	<code>_work\db__smoketest_repo_<hash>\</code>	
SARIF grezzi (output CodeQL per query)	<code>_work*.sarif</code>	
Query generate dai template	<code>generated_queries\taint_<hash>.ql</code> , <code>generated_queries\apimisuse_<hash>.ql</code>	
Log degli step (se rediretto)	a schermo su stderr, o nel file se usi <code>`2>&1</code>	Tee-Object run.log`

Verifiche rapide (PowerShell)

```
# le query generate dalla run di oggi (più recenti in alto)
Get-ChildItem generated_queries\*.ql | Sort-Object LastWriteTime -
Descending | Select Name, LastWriteTime

# leggere cosa ha iniettato il modello in una query
Get-Content generated_queries\taint_<hash>.ql
```

```
# il report  
Get-Content report_abliterated.md
```

Comando di riferimento

```
cd C:\Users\ladyc\Documents\TRAINEESHIP\CodeQL_Security_Agent  
python agent.py "_smoketest_repo" --model hf.co/criscarleo/Qwen2.  
5-Coder-7B-Instruct-abliterated:Q4_K_M
```

(Nota: percorso relativo senza backslash iniziale. Il 7B su CPU è molto più veloce del 14B per iterare.)